

Actividad 1: Análisis y planificación del pentest

Danae Itziar Frutero Gutiérrez

Hacker Women Council- Ethical Hacking

1. Objetivo del pentest

El objetivo del pentest en la aplicación Aurora Market es evaluar el nivel de exposición de la plataforma a los ataques cibernéticos. La evaluación es indispensable ya que permitirá conocer que información sensible podría estar en riesgo y cual sería el impacto de una explotación exitosa. Se pretende ofrecer a Aurora Market una visión clara de cómo un atacante podría aprovechar las debilidades del sistema y las consecuencias que tendría con los clientes, la continuidad de las operaciones y la reputación de la empresa, con el propósito de que la organización pueda tomar decisiones informadas y fortalecer su seguridad.

2. Alcance

Incluido:

- La aplicación web autorizada por Aurora Market

Excluido:

- Redes sociales de la empresa
- Equipos personales de los empleados
- Cuentas de correo de los empleados
- Proveedores externos
- Otros sistemas relacionados con la empresa

3. Autorización y condiciones

Permisos: Acceso a la aplicación, bases de datos, mecanismos de autenticación y tipos de usuarios

Condiciones:

- Las pruebas se realizarán en horarios de menos actividad para reducir cualquier impacto sobre las operaciones.
- No está permitido realizar acciones que puedan interrumpir el funcionamiento de la plataforma o afectar la información real de los clientes.

4. Tipo de pentest

Gray Box: Se cuenta con información parcial, simulando el conocimiento limitado que tendría un atacante con acceso restringido.

5. Planificación

Que debería hacer el equipo antes de comenzar la parte técnica:

Objetivos: Realizar una evaluación que permita conocer qué tan expuesta está la aplicación web de Aurora Market a ataques cibernéticos; identificando los riesgos que existe, evaluando el impacto que podrían tener y proponiendo medidas que permitan reducirlos. Las actividades que el equipo debería hacer antes de comenzar: identificar vulnerabilidades técnicas y de configuración; determinar el impacto que tendría la explotación de dichas vulnerabilidades en la seguridad de los clientes y las operaciones.

Alcance: Se evaluará la aplicación web autorizada por Aurora Market. El equipo debería familiarizarse con el entorno de la aplicación antes de comenzar.

Permisos y condiciones: El equipo debe tener claro las condiciones antes de empezar: No se evaluarán las redes sociales de los empleados, sus cuentas de correo, ni de proveedores externos. No se evaluarán otros sistemas relacionados con la empresa. No se realizarán acciones que puedan interrumpir deliberadamente el funcionamiento de la plataforma o que puedan afectar información real de los clientes.

Metodología a utilizar: PTES (Penetration Testing Execution Standard) complementada con guías de OWASP para seguridad en aplicaciones web. Para asegurar un proceso estructurado y enfocado en riesgos reales.

Recopilación de información previa: Se pretende tener un mapa claro de la infraestructura y posibles puertos de entrada: OSINT: Whois y DNSdumpster para identificar dominios, subdominios y registros DNS, Nmap para detectar puertos abiertos y servicios activos.

Recursos necesarios: Computadora con sistema operativo seguro y actualizado, documentación sobre PTES y OWASP, de escaneo y análisis (Nmap, ZAP, DNSdumpster), conexión segura y estable.

Programación del pentest: Se realizará de forma acordada con Aurora Market, una vez que se proporcione la información necesaria y verificar que sea horario de menor actividad, que podrían ser horarios nocturnos (de 0:00 a 6:00 hrs). La elección de este horario reduce el riesgo de operaciones reales y garantiza el menor impacto de la prueba.

6. Fases del pentest

¿Qué buscarías hacer en cada etapa?

1. **Reconocimiento:** Leer la documentación proporcionada por Aurora Market, incluido de forma detallada el reporte del usuario, en el que aseguraba haber visto información que aparentemente pertenecía a otra cuenta. Recopilar información pública y privada sobre la aplicación web con las herramientas Whois y DNSdumpster.
2. **Análisis de vulnerabilidades:** Utilizar herramientas que permitan detallar los activos de la empresa y ver cuáles de sus características podrían ser una vulnerabilidad, por ejemplo, versiones desactualizadas y ejecutar escaneos con Nmap para identificar vulnerabilidades técnicas.



3. **Explotación:** Se intentará explotar las vulnerabilidades detectadas, siempre dentro del alcance. Por ejemplo, probar si un fallo de autenticación permite acceder a cuentas de usuario sin credenciales válidas.
4. **Post-Explotación:** Se evaluará el impacto de la explotación y si puede persistir, ver hasta que punto cierta información o sistemas pueden verse comprometidos.
5. **Informe:** Se utilizará la plantilla de PTES para elaborar un reporte claro y estructurado, para entregar a Aurora Market un documento que sirva como guía para mejorar su seguridad.

7. Investigación

Metodología elegida

La metodología empleada será **PTES** debido a que es mi primer pentest y eso me permitiría tener un esqueleto claro, paso a paso de la prueba, además podría complementarlo consultando documentación de OWASP debido a su enfoque en seguridad de aplicaciones web. Garantizando así un proceso estructurado.

